> vulnerability breakdown

Faille Wi-Fi Broadcom WPS

Prise de contrôle d'une box
sans mot de passe, par radio

Type
Débordement mémoire → exécution de code

Accès
Pré-authentification, à portée radio

Composant
Puces Wi-Fi Broadcom (firmware)

Statut
16 ans d'âge — toujours AUCUN CVE

Recherche : Quentin Kaiser — Hexacon, oct. 2026

LE CONTEXTE

WPS : se connecter au Wi-Fi sans taper la clé

WPS — Wi-Fi Protected Setup

appairage « par bouton », sans saisir la clé

géré par le firmware de la puce Wi-Fi

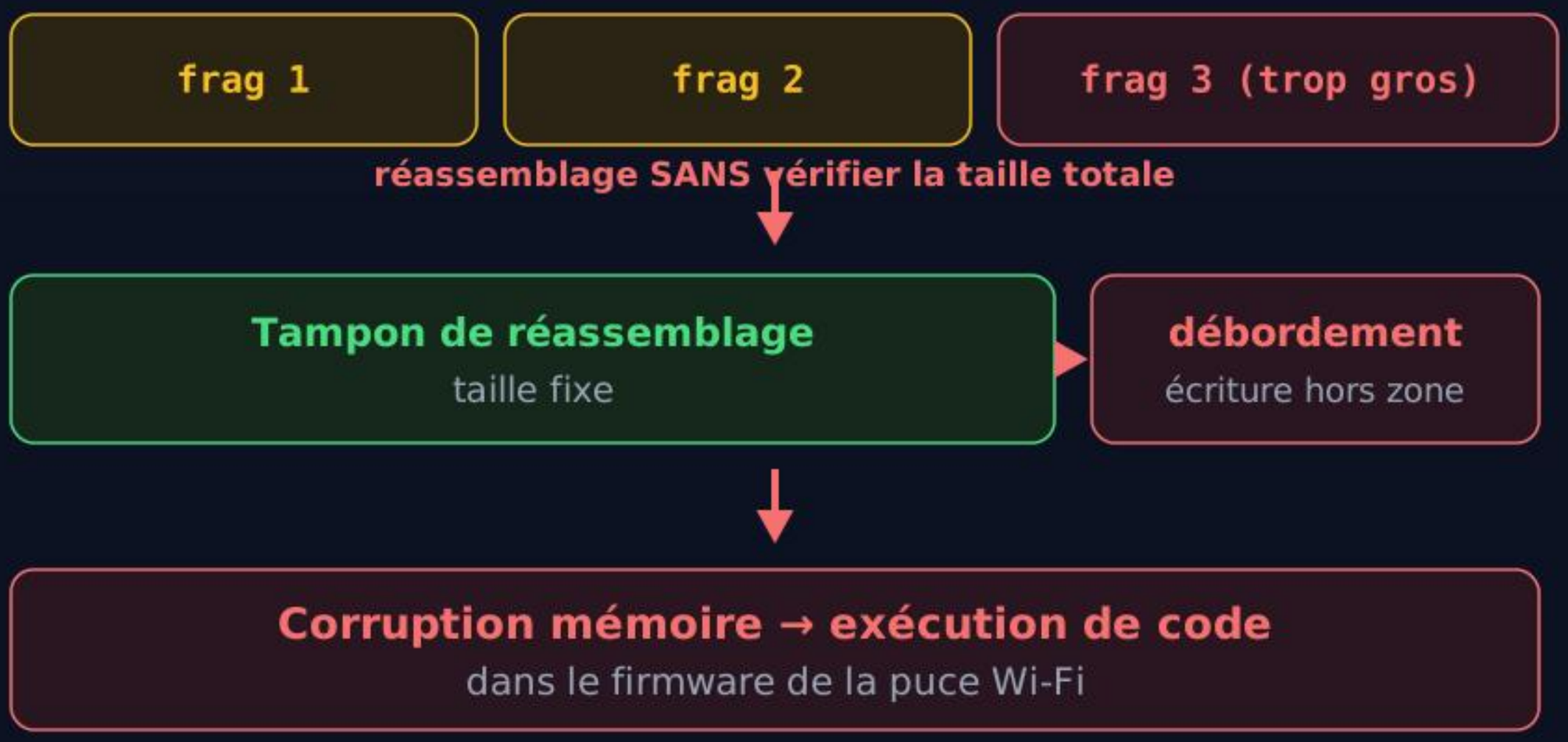
Puces Broadcom

le même code WPS équipe des millions
de box et routeurs (eCos ET Linux)

Le WPS répond AVANT toute authentification :
la puce traite des messages d'un appareil pas encore connecté.
Une surface d'attaque ouverte à toute personne à portée radio.

LA VULNÉRABILITÉ

Un message recollé de travers



Le firmware recolle les fragments WPS/EAP sans borner la taille.
Un message fragmenté forgé déborde le tampon — le motif classique.

LE MOTIF, EN C

Réassembler sans borne

✗ **VULNÉRABLE — on copie chaque fragment sans compter**

```
uint8_t buf[256];          // tampon de taille fixe
size_t off = 0;
for (frag in fragments)  // messages WPS en morceaux
    memcpy(buf + off, frag.data, frag.len);
    off += frag.len;     // <-- off dépasse 256 : déborde
```

✓ **CORRIGÉ — on refuse ce qui dépasse le tampon**

```
uint8_t buf[256];
size_t off = 0;
for (frag in fragments)
    if (off + frag.len > sizeof(buf))   // <-- borne
        return ERROR;                   // on rejette
    memcpy(buf + off, frag.data, frag.len);
    off += frag.len;
```

Illustration du principe (pas le code réel de Broadcom).
La règle d'or : vérifier la taille AVANT d'écrire.

LE DANGER RÉEL

Pourquoi c'est bien pire qu'un overflow « classique »

À portée radio

pas besoin d'accès au réseau — juste être à proximité

Avant toute authentification

la clé Wi-Fi ne protège pas : l'attaque passe avant

Changer son mot de passe ne sert à rien

l'attaquant extrait même la clé depuis la mémoire

Exécution de code sur la box

contrôle du routeur = porte d'entrée du réseau

LA CHAÎNE

Du trottoir au contrôle de la box

Attaquant à portée radio
aucune clé, aucun compte

↓

Envoie un message WPS fragmenté forgé
traité avant authentification

↓

Le firmware le réassemble mal
débordement du tampon

↓

Exécution de code sur la puce Wi-Fi
shell root / reverse shell en 802.11

↓

Contrôle de la box + clé Wi-Fi volée
porte d'entrée de tout le réseau

Tout ça à distance, sans jamais connaître le mot de passe.
La box, censée protéger le réseau, devient le point d'entrée.

L'ANGLE MORT

16 ans, un demi-correctif, et aucun CVE

~2010
Le bug est introduit dans le code WPS Broadcom

2018
Correctif silencieux… et incomplet

2026
Toujours exploitable — démontré à Hexacon

CVE
Refusé par Broadcom (qui est lui-même l'autorité)

Sans CVE, pas de suivi centralisé : chaque fabricant corrige (ou pas) dans son coin. C'est l'utilisateur qui porte le risque.

SE PROTÉGER

Ce qu'on peut faire

1. **Désactiver le WPS**
   si on ne s'en sert pas — réduit le risque, sans garantie
2. **Appliquer les mises à jour box**
   surveiller les annonces de l'opérateur (auto en principe)
3. **Couper le Wi-Fi de la box → Ethernet**
   radical mais efficace : plus de radio vulnérable
4. **Box en bridge + routeur OpenWrt**
   avancé : la box en simple modem, Wi-Fi par hostapd
5. **Côté fabricant : corriger le code**
   borner le réassemblage, migrer vers hostapd

L'utilisateur ne peut que réduire la surface d'attaque —
le vrai correctif est entre les mains des fabricants.

Un bug de dev

dans une puce que personne ne regarde

Un message mal réassemblé,
une mémoire mal gérée.
L'embarqué est le maillon faible.

Writeup détaillé + mes labs

github.com/Yann0511/pwn-labs

D'après la recherche publique de Quentin Kaiser (Hexacon 2026).
Vulgarisation à des fins pédagogiques — aucun exploit armé.